

EXPERIMENT 1.b.

you have received a suspicious binary file named suspicious.bin, which is suspected to be a Windows-based malware sample. Without executing the file, perform static analysis to determine whether it belongs to a potential malware family such as a Trojan or backdoor.

The file has been derived from an existing Windows PE executable and modified to include suspicious API calls and persistence-related strings commonly associated with malicious behavior (e.g., process injection APIs, command execution strings, registry autorun keys).

Tool: YARA

Important Disclaimer: We will NOT use live malware binaries. That would be unsafe and unethical. Instead, we use malware *signatures* embedded into test binaries.

Procedure (Steps for performing experiment)

In Kali Linux VM

✓ **Update and Upgrade**

```
sudo apt update && sudo apt upgrade -y
```

Note: If already updated and upgraded this cmd can be ignored.

✓ **Install yara**

```
sudo apt install yara -y
```

✓ **yara version**

```
yara --version
```

1. Use existing windows PE binary

Kali includes windows binary here

```
ls /usr/share/windows-resources/binaries/
```

There are some binaries which are available, copy one here:

```
cp /usr/share/windows-resources/binaries/nc.exe suspicious.bin
```

```
chmod -x suspicious.bin
```

2. Then verify whether it is a Windows PE file

```
file suspicious.bin
```

the expected output must be:

```
suspicious.bin: PE32 executable for MS Windows 4.00(Console), Intel i386, 4 sections
```

3. Now create a generic windows yara rules:

```
vi windows_malware_generic.yar
```

```
rule windows_malware_generic
```

```
{
```

```
  meta:
```

```
    author = "Students"
```

```
    description = "Generic Windows PE malware detection using static indicators"
```

```
    malware_type = "Trojan / Backdoor (Generic)"
```

```
  strings:
```

```
    $api1 = "CreateRemoteThread" ascii nocase
```

```
    $api2 = "VirtualAllocEx" ascii nocase
```

```
    $api3 = "WriteProcessMemory" ascii nocase
```

```
    $cmd = "cmd.exe" ascii nocase
```

```
    $reg = "CurrentVersion\\Run" ascii nocase
```

```
  condition:
```

```
    uint16(0) == 0x5A4D and
```

```
    any of ($api*) or ($cmd or $reg)
```

}

4. Then add these strings

```
echo "CreateRemoteThread" >> suspicious.bin
```

```
echo "cmd.exe" >> suspicious.bin
```

```
echo "VirtualAllocEx" >> suspicious.bin
```

Then verify by using below cmd:

```
strings -a suspicious.bin | grep -Ei "createremotethread|cmd.exe"
```

Then output shows like below

```
createRemoteThread
```

```
Cmd.exe
```

Then Run Yara against binary file

```
yara windows_malware_generic.yar suspicious.bin
```

Possible Results

- No output → benign PE (expected for nc.exe)
- Rule name printed → suspicious indicators found

Both results are valid for the experiment.

Result

- The suspicious binary contains known malware-related strings
- YARA rules successfully detected the file based on static signatures
- No execution of the file was required.